Кібербезпека як конкурентна перевага

Як відповідність вимогам безпеки відкриває нові ринки



Іван Гокін

ПРО МЕНЕ

Познайомимося

ІМ’Я	**Іван Гокін**
РОЛЬ	IT-аудитор
СЕРТИФІКАЦІЯ	CISA — Certified Information Systems Auditor
ДОСВІД	5+ років у консалтингу та аудиті
LINKEDIN	linkedin.com/in/ivan-gokin

ГОЛОВНА ДУМКА

Довіра відкриває ринки

Підтверджена безпека скорочує цикл угоди і знімає зайві запитання від замовника.

69%

користувачів британського базового сертифіката Cyber Essentials кажуть, що він підвищив їхню конкурентоспроможність

33%

їхніх контрактів за рік вимагали цей сертифікат

65%

великих компаній називають слабкість постачальників головною перешкодою своїй кіберстійкості

Джерела: Cyber Essentials Impact Evaluation, уряд Великої Британії, 2024; WEF Global Cybersecurity Outlook 2026

ПЛАН

Що ми обговоримо

I

Хто полює за вашими технологіями

Шпигунство в оборонній галузі України та Європи

II

Захист без зайвих витрат

Облік активів і розробки, помилки, шість засобів, облікові записи, свої пристрої й виробництво

III

Довіра замовника

Вимоги замовника, безпека продукції, ISO/IEC 27001, інцидент і відновлення

IV

Люди й гроші

Ціна бездіяльності, хто це робить, уся програма і перші 90 днів

Абревіатури простою мовою — у словнику наприкінці.

Хто полює за вашими технологіями

Шпигунство й крадіжка розробок в оборонній галузі України та Європи

МАСШТАБ ЗАГРОЗ

Атак стає більше

5 927

кіберінцидентів опрацювала CERT-UA у 2025 році

+37%

порівняно з 2024 роком

Дані підприємств оборонно-промислового комплексу — серед найцінніших цілей.

Джерело: CERT-UA, підсумки 2025 року, за dev.ua

ЛАНЦЮГ ПОСТАЧАННЯ

Кожна компанія – частина ланцюга постачання

Постачальник матеріалів / послуг → **Виробник компонентів** → **Генеральний підрядник / інтегратор** → **Кінцевий замовник** → **Користувач**

Чому малий і середній бізнес – приваблива ціль для атаки на ланцюг постачання

- Менша зрілість кібербезпеки — легший початковий доступ
- Відносини довіри із замовниками
- Доступ до технологій, інтелектуальної власності й виробничих даних
- Часто немає виділеної, спроможної команди кібербезпеки

48% зламів — за участі третьої сторони; рік тому було близько 30% (Verizon DBIR 2026). Схема — за ResearchGate.

П’ять кіберзагроз, які треба знати в ОПК

Загроза	Звідки	Як це виглядає для працівника
1. Фішинг у месенджерах	рф; частина — не встановлено	«Знайомий» або новий контакт у Signal чи WhatsApp надсилає архів або документ
2. Фальшиві вакансії й резюме	КНДР, рф	«Робота мрії» з програмою для тестового завдання; «резюме» в архіві для відділу кадрів
3. Злам периметра	Китай, рф	Нічого не видно: зловмисник місяцями сидить у неоновленому VPN, роутері чи камері
4. Листи від імені відомств	Білорусь, рф	Лист від «міністерства» чи партнера з PDF або архівом — іноді зі справжньої, але зламаної скриньки
5. Масові розсилки як двері	рф	Звичайний масовий лист; за ним — тихий доступ до найцінніших комп’ютерів

Людський фактор — у 62% зламів; найчастіший спосіб входу — вразливості (31%), за Verizon DBIR 2026.

II

Захист без зайвих витрат

Облік активів, типові помилки, шість засобів, свої пристрої й виробництво — те, про що спитає замовник

ПРИНЦИП

Та сама програма, лише простіша

Складова	Велика компанія	Мала компанія
Облік активів	Спеціалізована система	Таблиця, яку хтось веде
Політики	Десятки документів	Кілька коротких правил
Моніторинг	Власний цілодобовий центр (SOC)	Зовнішня чергова служба (MDR)
Реагування	Власна команда	Відповідальна особа, провайдер, CERT-UA
Безперервність	Повні плани безперервності й відновлення	1–2 сторінки на план, тест раз на рік
Сертифікація	ISO/IEC 27001 на всю організацію	ISO/IEC 27001 на ключову частину

Відмінність — не в складових, а в простоті: лише те, без чого не можна.

ОСНОВА

Облік активів — усе ще основа

Кожен засіб далі спирається на перелік: що в нас є, де воно і хто ним керує.

Пристрої

ПК, ноутбуки й телефони — зокрема особисті, з яких заходять до робочих даних.

Хмарні сервіси

Усі підписки, хто в них адміністратор і які дані там лежать.

Обладнання

Контролери, пульти, верстати — і хто керує ними ззовні, зокрема через хмару виробника.

Дані

Де лежать робочі дані й розробки. Про розробки — на наступному слайді.

ЩО ЗАХИЩАТИ

Почніть із ваших розробок

Шпигунам потрібні креслення, моделі й результати випробувань. Захист починається з питання: де вони лежать?

01

Знайдіть

Де лежать креслення, CAD-моделі, результати випробувань і листування із замовником.

02

Обмежте

Доступ — лише тим, кому потрібен. Окреме сховище, журнал доступу, окремі копії.

03

Передавайте безпечно

Із замовником і підрядниками — погодженим захищеним каналом, а не в месенджері чи на флешці.

04

Стежте

Масове копіювання чи вивантаження — сигнал для моніторингу.

ТИПОВІ ПОМИЛКИ

Дешеве рішення, яке не захищає

Антивірус замість EDR

Галочка є, а засобу, що бачить і зупиняє атаку на ПК (EDR), немає.

Міжмережевий екран «з коробки»

Куплений міжмережевий екран, а віддалений доступ відкритий.

Сповіщення, які ніхто не читає

Засіб бачить атаку, але реагувати нікому.

Копії, які ніхто не відновлював

І які лежать у тій самій мережі, що й зламані системи.

Відкрите ПЗ без людей

Економія на ліцензіях іде на зарплати тих, хто його налаштовує.

Усе на одній людині

Про це — у частині «Люди й гроші».

Вимагачі намагалися скомпрометувати резервні копії у 94% жертв, і 57% таких спроб вдалися (Sophos, 2024).

ПЕРШІ ЗАСОБИ

Шість засобів, з яких варто почати

Периметр	◆ Захист пошти
Мережа	◆ Міжмережевий екран і сегментація
Кінцеві пристрої	◆ Централізований EDR ◆ Оновлення ◆ MFA
Застосунки	Наступний етап
Дані	◆ Резервні копії з тестом відновлення
Критичні системи й дані	

◆ першочергово

Спрощено за NATSAR, Defense-in-Depth; копії додано

Вони закривають шляхи, якими заходять шпигуни: пошту, облікові записи й периметр.

Міжмережевий екран захищає офіс і виробництво, а ноутбуки поза офісом — EDR. Решту засобів — коли ці шість працюють.

Ціна — у частині IV, розбивка — у додатку.

АРХІТЕКТУРА

Свої пристрої й кілька хмар

РЕАЛЬНІСТЬ

Свої ноутбуки, кілька хмар

Люди працюють з власних ноутбуків і телефонів, дані — у кількох хмарах. Без капітальних витрат і без очікування на «залізо».

НАСЛІДОК

Класичного периметра немає

Офісна мережа не захищає ноутбук удома чи дані в хмарі. Межа тепер — пристрій і обліковий запис.

ЩО РОБИТИ

Охоронець на кожному пристрої

Централізований EDR на кожному пристрої з доступом до робочих даних. Вхід — лише з таких пристроїв і з MFA.

ОБМЕЖЕННЯ Службова інформація замовника — не на особистих пристроях і не в публічних хмарах, а лише в системі з підтвердженим захистом.

ЛЮДИ Й ДОСТУПИ

Облікові записи, месенджери, цифрові сліди

Облікові записи

- Апаратні ключі для пошти й адміністраторів
- Без кодів у SMS
- Старі способи входу без MFA — вимкнути
- Окремі облікові записи для адміністрування

Месенджери

- Незвичне прохання чи файл — перевірити іншим каналом
- Регулярно дивитися «пов’язані пристрої»
- PIN на реєстрацію номера
- Архіви з месенджерів не відкривати на робочих ПК

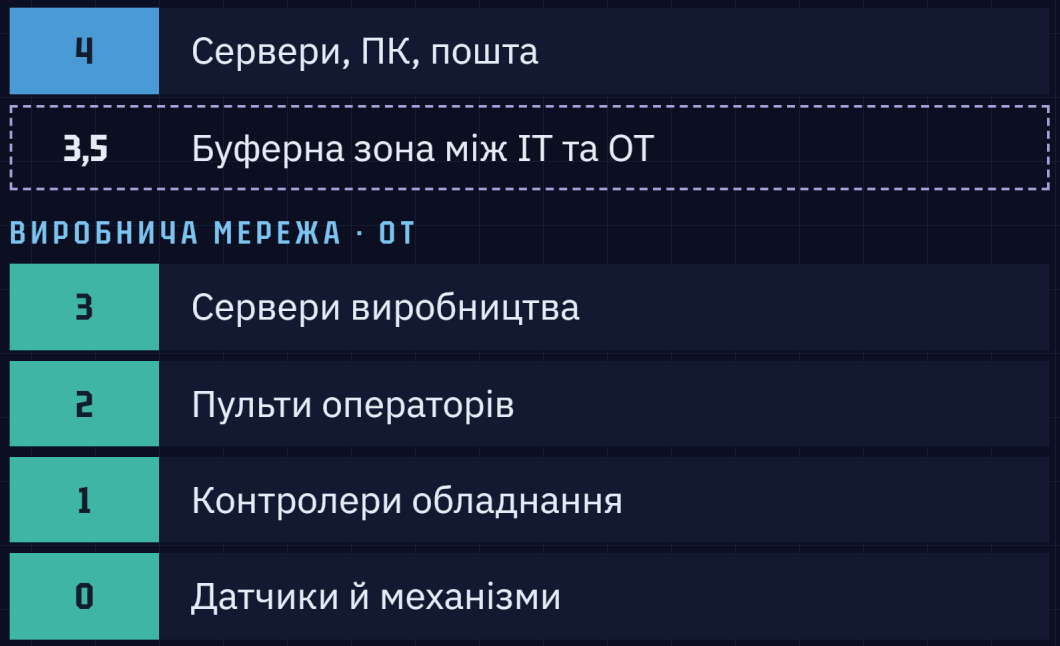
Сліди й люди

- Без фото й геотегів з території
- Підозрілі «рекрутери» — до відповідальної особи
- Звільнення чи мобілізація — доступ закрити того ж дня
- Втрачений телефон — одразу вийти з пошти й месенджерів

MFA блокує понад 99% атак на облікові записи (Microsoft Digital Defense Report 2025).

ВИРОБНИЦТВО

Безпека виробничого обладнання



Рівні виробничої мережі. Спрощено за Zscaler

Доступність понад усе

Захист не має зупиняти лінію, тому трафік слухають пасивно.

Без хмарного керування

Частина обладнання керується через хмару виробника, зокрема китайську. Обирайте локальне керування або «приземляйте»: ізолюйте й обмежте зв’язок назовні.

Інтегратори й дешеві кроки

Програми віддаленого доступу з пультів — прибрати; копії програм контролерів — офлайн; USB — під контролем.

III

Довіра замовника

Вимоги замовника й ринку, безпека продукції, ISO/IEC 27001, інцидент і відновлення

ДОВІРА ЗАМОВНИКА

Що попросить замовник

Опитувальник безпеки

Десятки питань про MFA, копії, доступи, інциденти й постачальників.

Відповідальна особа

Хто відповідає за безпеку і з ким говорити, коли щось сталося.

Політики й підтвердження

Набір політик, сертифікат ISO/IEC 27001 або самооцінка за вимогами замовника.

Результати перевірок

Короткий підсумок тестування на проникнення чи аудиту.

Повідомлення про інциденти

Строки — у договорі. Для продуктів на ринку ЄС — ще й за CRA.

Ваші постачальники

Замовник перевіряє ланцюг далі за вами — і ви маєте перевіряти своїх.

У Британії 48% великих і 30% середніх компаній формально перевіряють кіберризики постачальників (CSBS 2025/26).

ДОВІРА ЗАМОВНИКА

Приклад: Міноборони Британії

З кінця 2025 року — четверта версія Cyber Security Model. Вимоги йдуть по ланцюгу аж до субпідрядників.

01

Оцінка ризику

Замовник визначає рівень ризику контракту — від 0 до 3.

02

Опитувальник

Постачальник оцінює себе онлайн і одразу бачить, чи відповідає.

03

План покращень

Не відповідаєте — це ще не відмова: план усунення прогалин стає частиною договору.

04

Щороку

Новий опитувальник. Ваші субпідрядники — через власну оцінку ризику.

ДЛЯ ВАС Якщо ви субпідрядник британського постачальника, ці вимоги прийдуть до вас через договір. Рівень 0 — 3 вимоги, рівень 1 — уже 101.

Джерела: gov.uk, Cyber Security Model; кількість вимог за DEFSTAN 05-138, огляд Infinum

ДОВІРА ЗАМОВНИКА

Які вимоги стоять за питаннями

В УКРАЇНІ

Закони й держконтракти

- Закони № 2163-VIII і № 4336-IX — якщо ви об’єкт критичної інформаційної інфраструктури (КІІ) або працюєте з державними ресурсами
- Службова інформація замовника — лише в системах із підтвердженим захистом

РИНКИ ЄС І США

Через договори й продукти

- NIS2 (директива ЄС) — через вимоги європейських замовників
- CRA — для продуктів із цифровими елементами
- CMMC (вимоги Міноборони США) — лише для його контрактів

Вимоги до продукту — на наступному слайді. Вимоги до компанії закриває одна система управління.

ДОВІРА ЗАМОВНИКА

Безпека продукції

Продукт «з коробки» приносить ризики, які покупець не контролює.

Що несе ваш продукт

- Прошивки й програми: хто може їх змінити
- Компоненти інших виробників, зокрема з Китаю
- Дані, які продукт збирає й передає
- Залежність від хмари виробника

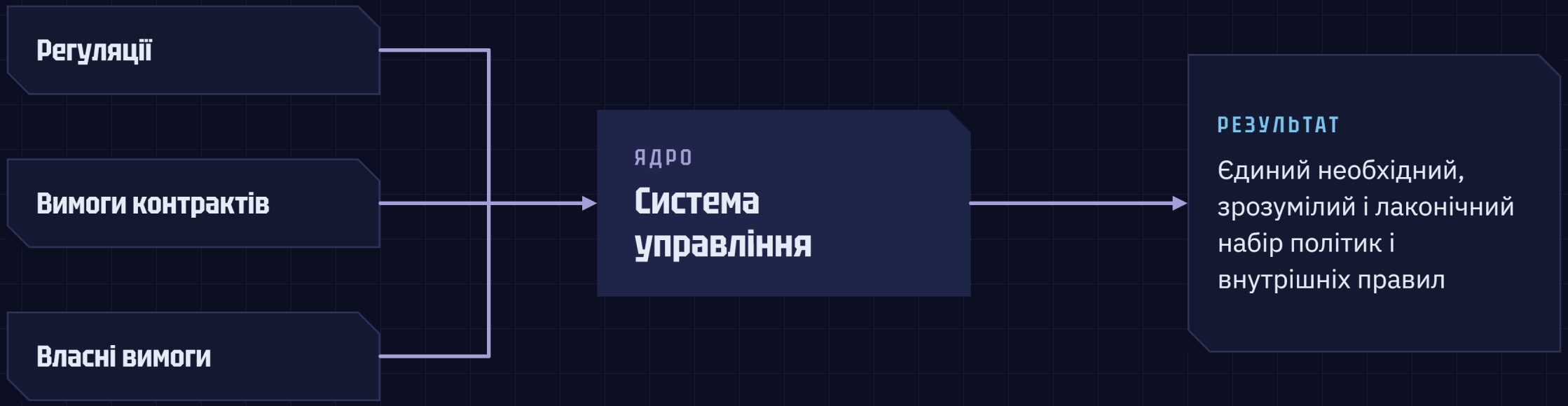
Що вимагає ЄС (CRA)

- Безпека закладена ще на етапі розробки
- Перелік компонентів і робота з вразливостями
- Оновлення безпеки щонайменше 5 років
- Вразливість, яку вже використовують, — повідомити державну команду реагування (CSIRT) і ENISA за 24 години

Звітування вже діє з 11.09.2026, решта вимог — з 11.12.2027. Продукти суто для оборони — поза CRA, а цивільна чи подвійна версія на ринку ЄС під нього підпадає.

ДОВІРА ЗАМОВНИКА

Інтеграція вимог



Відповідність зручно демонструвати зрілою системою управління. Сертифікат ISO/IEC 27001 до того ж закриває багато питань замовника.

Рамка: ISO/IEC 27001

Окремої української рамки для малих компаній поки немає. Найпрактичніший вибір — ISO/IEC 27001.

Сертифікат

Зовнішнє підтвердження, яке замовники часто вимагають у тендерах і договорах.

Ціна

Сертифікація — у середньому $4–10 тис. Впровадження — ≈ 0,3–0,5 ставки фахівця на 6–12 місяців. Оцінка автора.

Свій обсяг

Сферу сертифікації визначаєте ви: можна почати з тієї частини, що працює із замовником.

Інші рамки (NIST CSF, CIS Controls) — довідник, а не мета. CMMC — лише для контрактів Міноборони США.

ДОВІРА ЗАМОВНИКА · СТІЙКІСТЬ

Інцидент: перші години

1 Ізолюйте
Від мережі й інтернету, якщо можете

2 Збережіть докази
Не вимикайте: увімкнений, але ізольований

3 Зверніться до CERT-UA
Контакти — нижче

4 Повідомте замовника
Якщо цього вимагає договір

5 Відновлюйтеся
З копій — коли зрозуміло, як зайшли

КРОК 3 · CERT-UA

incidents@cert.gov.ua

044 281-88-25 — робочі години
044 281-88-01 — вихідні й свята

Оборонним підприємствам — також регіональне управління СБУ

НАВІЩО ПОВІДОМЛЯТИ

Ваші дані допомагають зупинити таку саму кампанію проти інших, а ви можете отримувати попередження про чужі.

ДОВІРА ЗАМОВНИКА · СТІЙКІСТЬ

Безперервність: BCP і DRP

Малій компанії кілька днів простою можуть коштувати контракту. Плани потрібні саме тому, що запасу немає.

BCP · ПЛАН БЕЗПЕРЕРВНОСТІ

Як працювати без IT

Як виробляти й постачати, коли системи чи світло недоступні: ручний режим, хто ухвалює рішення, як зв’язатися із замовником.

DRP · ПЛАН ВІДНОВЛЕННЯ

Як повернути IT

Що відновлюємо першим, з яких копій і за який час; хто це робить і де лежать інструкції — офлайн.

МІНІМУМ 1–2 сторінки на кожен план. Раз на рік — навчання «за столом» і пробне відновлення.

IV

Люди й гроші

Скільки коштує бездіяльність, хто робить кібербезпеку і скільки коштує вся програма — а потім з чого почати

Скільки коштує нічого не робити

$1,7 млн

у середньому коштує відновлення після атаки вимагачів — без викупу

34%

тих, чиї дані зашифрували, не відновилися з резервних копій

Дні простою

Зірвана поставка — неустойки за договором і втрачене місце в черзі замовника

Повна програма на рік коштує в рази менше за одне таке відновлення.

Джерело: Sophos State of Ransomware 2026 — середнє для компаній на 100–5000 людей, 17 країн

Чому всі функції кібербезпеки на одній людині – погана ідея



Джерело: cybersec.net.ua

Широта несумісна з глибиною

Людина – єдина точка відмови

Вигорання знищує захист повільно, але гарантовано

58% жертв вимагачів назвали однією з причин брак людей чи навичок (Sophos, 2026).

Які компетенції потрібні

Керівник з кібербезпеки (CISO чи vCISO)
Перша точка контакту з третіми сторонами

Правила, документи й відповідність
Система управління безпекою, відповіді на опитувальники замовників

Реагування на інциденти
Цілодобово — ≈ 5,5 ставки з відпустками, тому реалістичніше як послуга MDR

Впровадження захисту
Архітектура кібербезпеки — своїми силами чи з інтегратором

Це компетенції, а не посади: їх закривають власні люди або зовнішні MDR і vCISO.

Корисно також розуміти загрози й уміти розбирати шкідливі програми · описи ролей — за ENISA ECSF

Уся програма: скільки на рік

Складова	На рік, орієнтовно
Ліцензії: EDR, керування пристроями, MFA, захист пошти · 100 користувачів; 30 апаратних ключів	≈ $28 800
Міжмережевий екран, сегментація, резервні копії	$2 100–22 500
Тестування на проникнення раз на рік і навчання персоналу	$5 000–18 000
Відповідальна особа: CISO у штаті чи vCISO	$24 000–78 000
Цілодобове реагування — послуга MDR · 100 пристроїв	$10 000–36 000
Разом · $700–1 830 на працівника на рік	≈ $70–183 тис.

від ≈ $45 тис. старт, якщо офісний пакет уже оплачено

Без MDR: власна зміна 24/7 — ≈ 5,5 ставки, ≈ $170 тис. на рік

Модель — свої пристрої й хмари; з власним обладнанням — див. додаток. Не в сумі: впровадження (свій IT чи інтегратор), система для службової інформації, ISO/IEC 27001 ($4–10 тис.). Оцінка автора.

З ЧОГО ПОЧАТИ

Перші 90 днів

ДНІ 1-30

- Відповідальна особа й контакти на інцидент
- Облік активів: пристрої, хмари, обладнання, дані
- Апаратні ключі MFA для пошти й адмінів
- Віддалений доступ, роутери, камери: закрити зайве, оновлювати першими
- Офлайн-копії і пробне відновлення

ДНІ 31-60

- EDR на всіх пристроях і цілодобова чергова служба
- Захист пошти й домену від підробки
- Журнали — в одне місце
- Канал «повідомити про підозріле» і правила для месенджерів

ДНІ 61-90

- Сегментація; хмарне керування обладнанням — прибрати чи ізолювати
- Доступ до розробок — лише кому треба
- Базові політики й відповіді на опитувальник
- Плани безперервності й відновлення
- Перші метрики для замовника

Опори: ISO/IEC 27001 · попередження CERT-UA

ЩО ВИ ОТРИМУЄТЕ

Що дає ця програма і що далі

Захист від найчастіших атак	Докази для замовника: метрики й відповіді	Готовність до сертифікації ISO/IEC 27001	Основа для подальшого розвитку

Що далі — залежить від розміру компанії, за порогами NIS2:

ДО 50 ЛЮДЕЙ · МАЛЕ

Стартового набору достатньо

Від ≈ $45 тис. на рік. Підтримуйте: метрики щокварталу, раз на рік — пробне відновлення.

50-249 ЛЮДЕЙ · СЕРЕДНЕ

Уся програма + NIS2

NIS2 може діяти напряму: усі заходи ст. 21, пропорційно розміру. Власний периметр і робочі пристрої.

250+ ЛЮДЕЙ · ВЕЛИКЕ

Власна команда

Ті самі заходи NIS2, але своїми людьми й системами; ISO/IEC 27001 — на всю компанію.

ЗРОСТАННЯ Більша компанія — складніші структура й IT: свій периметр, свої пристрої й сервери. Разом із ними ростуть і бюджет, і команда.

ПІДСУМОК

Довіра, яку можна показати

Шпигуни заходять через людей, периметр і постачальників

Досить простої програми — але не на одній людині

Вона коштує в рази менше за один інцидент



Підтверджена безпека — ваш міст до замовника

Через 90 днів показуйте замовнику не обіцянки, а чотири цифри:

Покриття MFA і EDR

Частка облікових записів із MFA і пристроїв з EDR. Ціль — 100%

Швидкість оновлень

Днів до встановлення критичного оновлення на периметрі. Ціль — до 14 днів

Останнє відновлення

Дата останнього пробного відновлення з копії. Ціль — не рідше разу на рік

Повідомлення про підозріле

Скільки людей повідомили про підозріле. Ціль — більше з кожним кварталом



Дякую

Запитання й обговорення

Іван Гокін

linkedin.com/in/ivan-gokin

ДОДАТОК

Словник для власника

EDR — охоронець на кожному комп’ютері й телефоні: бачить атаку і зупиняє її

MDR — зовнішня чергова служба 24/7, яка стежить за сигналами EDR і реагує

SOC — цілодобовий центр моніторингу безпеки, власний чи від підрядника

MFA · апаратний ключ — вхід із другим підтвердженням · фізичний ключ замість коду з SMS

SPF · DKIM · DMARC — налаштування пошти, щоб від вашого імені не слали фальшиві листи

VPN — захищене підключення до робочої мережі ззовні; часта ціль атак

ОПК · CERT-UA — оборонно-промисловий комплекс · урядова команда реагування на кіберінциденти

CMMC — вимоги Міноборони США до кібербезпеки підрядників

BCP · DRP — план, як працювати без IT · план, як відновити IT

CISO · vCISO — керівник з кібербезпеки · такий керівник на аутсорсі

OT — виробниче обладнання і мережа цеху

ISO/IEC 27001 — міжнародний стандарт і сертифікат системи управління безпекою

CRA — регламент ЄС про безпеку продуктів із цифровими елементами

NIS2 — директива ЄС про кібербезпеку середніх і великих компаній

КІІ — критична інформаційна інфраструктура — об’єкти з особливими вимогами закону

CSIRT · ENISA — державна команда реагування на інциденти · агенція ЄС з кібербезпеки

Скільки коштують шість засобів на рік

Засіб · обсяг	Власне обладнання	Хмара
Захист пошти · 100 скриньок	$5 000–8 000	$0–2 400*
Міжмережевий екран · 3 пристрої або 1 хмарний	$10 500–13 500 у перший рік, далі ≈ $3 000–4 500	$1 500–5 000
EDR · 100 пристроїв	$3 000–6 000	$0–3 600*
Оновлення · 100 пристроїв	$200–2 500	$0*
MFA · 100 користувачів	$3 600–7 200	$0–7 200*
Резервні копії · ~20 систем	$5 000–9 000	$600–3 000
Разом	≈ $27 300–46 200 у перший рік	≈ $2 100–21 200*

Експертна оцінка. * $0 — засіб входить в офісний пакет ліцензій (≈ $22 на користувача на місяць, враховано в повному бюджеті). Апаратні ключі для MFA — разова закупівля, окремо.